

AUDITORÍA DE CUMPLIMIENTO E2E

Fase 1: Alta de Administraciones - Plataforma Partilot.es

INFORME DE CONSISTENCIA Y FLUJO E2E - FASE 1

Fase 1: Alta de Administraciones y Validación de Seguridad

Metadato	Detalle
Proyecto	Auditoría Ciberseguridad E2E (ID: proj_1782286766527)
Fecha/Hora	24/6/2026, 11:14:03
Entorno	Local Development (macOS)
Sorteo Simulado	ID del Sorteo: 78
Tipo de Flujo	Sorteo Pasado
Estado de Fase	Completada con Éxito

1. Resumen de Administraciones Creadas

Se han registrado en la base de datos las siguientes administraciones con datos realistas:

ID	Administración	Email de Contacto	Username Panel	Web	API Prepa
621	Administración de Loterías N° 1 'Doña Manolita 32442'	info@donamanolita32442.es	73135309	www.donamanolita32442.es	Activo
622	Administración de Loterías N° 2 'La Herradura de la Suerte 29177'	info@laherraduradelasuerte29177.es	49149284	www.laherraduradelasuerte29177.es	No
623	Administración de Loterías N° 3 'El Doblón de Oro 19947'	info@eldoblondero19947.es	62356426	www.eldoblondero19947.es	No
624	Administración de Loterías N° 4 'El Trébol de Cuatro Hojas 1939'	info@eltreboldecuatrohojas1939.es	10987893	No	No
625	Administración de Loterías N° 5 'El Búho Dorado 31944'	info@elbuhodorado31944.es	10073886	No	No

2. Auditoría Detallada de Almacenamiento y Consistencia

Se ha verificado la integridad de las tablas afectadas en la base de datos MySQL, validando que no existan codificaciones incorrectas (símbolos extraños) ni inconsistencias de relaciones:

ID	Tabla / Elemento	Estado	Observaciones / Errores
621	Tabla: <code>administrations</code>	 Correcto	Registro almacenado y verificado en la tabla <code>administrations</code> . Sin caracteres corruptos.
621	Tabla: <code>users</code> (Gestor)	 Correcto	Usuario gestor verificado en la tabla <code>users</code> . Rol correcto.
621	Tabla: <code>users</code> (Panel)	 Correcto	Usuario de acceso al panel verificado. Username único generado.
621	Tabla: <code>managers</code> (Principal)	 Correcto	Relación principal del gestor guardada correctamente en la tabla <code>managers</code> .
621	Tabla: <code>managers</code> (Panel)	 Correcto	Relación secundaria del panel guardada correctamente en la tabla <code>managers</code> .
621	Log: <code>email_communication_logs</code>	 Correcto	Log de envío registrado y enviado sin errores.
622	Tabla: <code>administrations</code>	 Correcto	Registro almacenado y verificado en la tabla <code>administrations</code> . Sin caracteres corruptos.
622	Tabla: <code>users</code> (Gestor)	 Correcto	Usuario gestor verificado en la tabla <code>users</code> . Rol correcto.
622	Tabla: <code>users</code> (Panel)	 Correcto	Usuario de acceso al panel verificado. Username único generado.
622	Tabla: <code>managers</code> (Principal)	 Correcto	Relación principal del gestor guardada correctamente en la tabla <code>managers</code> .
622	Tabla: <code>managers</code> (Panel)	 Correcto	Relación secundaria del panel guardada correctamente en la tabla <code>managers</code> .
622	Log: <code>email_communication_logs</code>	 Correcto	Log de envío registrado y enviado sin errores.
623	Tabla: <code>administrations</code>	 Correcto	Registro almacenado y verificado en la tabla <code>administrations</code> . Sin caracteres corruptos.
623	Tabla: <code>users</code> (Gestor)	 Correcto	Usuario gestor verificado en la tabla <code>users</code> . Rol correcto.
623	Tabla: <code>users</code> (Panel)	 Correcto	Usuario de acceso al panel verificado. Username único generado.
623	Tabla: <code>managers</code> (Principal)	 Correcto	Relación principal del gestor guardada correctamente en la tabla <code>managers</code> .
623	Tabla: <code>managers</code> (Panel)	 Correcto	Relación secundaria del panel guardada correctamente en la tabla <code>managers</code> .
623	Log: <code>email_communication_logs</code>	 Correcto	Log de envío registrado y enviado sin errores.
624	Tabla: <code>administrations</code>	 Correcto	Registro almacenado y verificado en la tabla <code>administrations</code> . Sin caracteres corruptos.

ID	Tabla / Elemento	Estado	Observaciones / Errores
624	Tabla: <code>users</code> (Gestor)	 Correcto	Usuario gestor verificado en la tabla users. Rol correcto.
624	Tabla: <code>users</code> (Panel)	 Correcto	Usuario de acceso al panel verificado. Username único generado.
624	Tabla: <code>managers</code> (Principal)	 Correcto	Relación principal del gestor guardada correctamente en la tabla managers.
624	Tabla: <code>managers</code> (Panel)	 Correcto	Relación secundaria del panel guardada correctamente en la tabla managers.
624	Log: <code>email_communication_logs</code>	 Correcto	Log de envío registrado y enviado sin errores.
625	Tabla: <code>administrations</code>	 Correcto	Registro almacenado y verificado en la tabla administrations. Sin caracteres corruptos.
625	Tabla: <code>users</code> (Gestor)	 Correcto	Usuario gestor verificado en la tabla users. Rol correcto.
625	Tabla: <code>users</code> (Panel)	 Correcto	Usuario de acceso al panel verificado. Username único generado.
625	Tabla: <code>managers</code> (Principal)	 Correcto	Relación principal del gestor guardada correctamente en la tabla managers.
625	Tabla: <code>managers</code> (Panel)	 Correcto	Relación secundaria del panel guardada correctamente en la tabla managers.
625	Log: <code>email_communication_logs</code>	 Correcto	Log de envío registrado y enviado sin errores.

3. Verificación de Comunicaciones (Mailpit)

Se han interceptado los correos de bienvenida de las administraciones. A continuación se muestra un único correo de ejemplo y el estado de envío del resto:

✉ **[EJEMPLO] Correo de bienvenida para: Administración de Loterías N° 1 'Doña Manolita 32442'**

- **Destinatario:** info@donamanolita32442.es
- **Usuario de Acceso:** 73135309
- **Estado del Envío:**  Enviado con éxito a través de SMTP y registrado en Mailpit.



✉ **Otros envíos realizados en esta fase:**

- **Administración:** Administración de Loterías N° 2 'La Herradura de la Suerte 29177'
- **Destinatario:** info@laherraduradelasuerte29177.es
- **Usuario de Acceso:** 49149284
- **Estado del Envío:** ● Enviado y registrado en Mailpit (Cuerpo del correo omitido en este reporte para simplificación).
- **Administración:** Administración de Loterías N° 3 'El Doblón de Oro 19947'
- **Destinatario:** info@eldoblondoro19947.es
- **Usuario de Acceso:** 62356426
- **Estado del Envío:** ● Enviado y registrado en Mailpit (Cuerpo del correo omitido en este reporte para simplificación).
- **Administración:** Administración de Loterías N° 4 'El Trébol de Cuatro Hojas 1939'
- **Destinatario:** info@eltreboldecuatrohojas1939.es
- **Usuario de Acceso:** 10987893
- **Estado del Envío:** ● Enviado y registrado en Mailpit (Cuerpo del correo omitido en este reporte para simplificación).
- **Administración:** Administración de Loterías N° 5 'El Búho Dorado 31944'
- **Destinatario:** info@elbuhodorado31944.es
- **Usuario de Acceso:** 10073886
- **Estado del Envío:** ● Enviado y registrado en Mailpit (Cuerpo del correo omitido en este reporte para simplificación).

5. Resumen de Defectos e Incumplimientos de Control (Auditoría)

A continuación se detallan los hallazgos críticos de cumplimiento y seguridad obtenidos en esta fase:

1. Ejecución Remota de Código (RCE) por Subida de Archivos Arbitraria:

- **Gravedad:** ● CRÍTICA
- **Detalle:** El parámetro `image` se recibe y almacena en el sistema de archivos (`public/images/`) sin validar su MIME type ni su extensión en las reglas de validación en `AdministratorController.php`, permitiendo la subida de un shell de PHP ejecutable.
- **Ejemplo de lo que puede pasar y por qué es importante:** Un atacante puede subir un archivo con extensión `.php` malicioso haciéndolo pasar por una imagen. Si el servidor web ejecuta PHP en el directorio de subidas, el atacante puede realizar llamadas al shell remoto y tomar control total del servidor de Partilot.es.

1. Contraseñas por Defecto en Creación de Gestor:

- **Gravedad:**  ALTA
- **Detalle:** Al dar de alta un administrador, si el gestor no existe en el sistema se crea con una contraseña fija hasheada (12345678) en AdministratorController.php en la línea 326.
- **Ejemplo de lo que puede pasar y por qué es importante:** Un atacante puede probar la contraseña provisional por defecto (12345678) contra los nombres de usuario de gestores recién creados. Si el gestor no la cambia inmediatamente, el atacante puede iniciar sesión y realizar acciones no autorizadas.

1. Credenciales de Integración en Texto Plano:

- **Gravedad:**  ALTA
- **Detalle:** La clave de API externa `prepago_api_key` se guarda directamente en texto plano en la base de datos sin cifrado en reposo al guardar en AdministratorController.php en la línea 223, exponiendo credenciales ante fugas de la base de datos.
- **Ejemplo de lo que puede pasar y por qué es importante:** Si la base de datos se ve comprometida o se extrae una copia de seguridad, un atacante podrá leer y reutilizar las claves de API del proveedor de prepago para emitir décimos sin pagar, provocando pérdidas directas.

1. Ausencia de Logs de Auditoría Bancaria:

- **Gravedad:**  MEDIA
- **Detalle:** Las modificaciones del campo `account` (IBAN de la administración) se aplican directamente en la base de datos en AdministratorController.php sin registrar un log de auditoría inmutable.
- **Ejemplo de lo que puede pasar y por qué es importante:** Un gestor malintencionado podría cambiar la cuenta bancaria de destino (IBAN) por una propia antes del cobro de premios o de las comisiones. Sin un log de auditoría inmutable, no sería posible determinar quién realizó el cambio ni cuándo, impidiendo cualquier análisis forense.

1. Validación Inconsistente de Código Postal:

- **Gravedad:**  MEDIA
- **Detalle:** La validación de longitud para códigos postales (`max:10`) no se aplica de manera estricta a nivel de formato numérico en el método de actualización del controlador, permitiendo guardar códigos inválidos o sobredimensionados en la base de datos. Se localiza en AdministratorController.php en la línea 117.
- **Ejemplo de lo que puede pasar y por qué es importante:** Si no se valida el formato del código postal, un atacante puede inyectar texto o código arbitrario. Esto puede provocar un desbordamiento o errores en la generación automática de remesas y facturas, o incluso inyecciones de código si el valor se renderiza en el panel.